

Politique de Sécurité de l'Information — TechShop SAS

Version : 1.0

Date : Juin 2026

Auteur : Dorian Poncelet (Consultant GRC)

Approuvée par : Marie Laurent, Directrice Générale

Statut : Validé

Référence : ISO 27001:2022 — Clause 5.2 / A.5.1

1. Contexte et périmètre

TechShop SAS est une entreprise de e-commerce spécialisée dans la vente de matériel gaming et électronique grand public (B2C et B2B revendeurs), basée à Toulouse. Avec un chiffre d'affaires de 3,2M€, 47 salariés et 15 000 clients actifs, TechShop traite quotidiennement des données personnelles sensibles et dépend de son infrastructure numérique pour la totalité de son activité commerciale.

La présente politique s'applique à :

- L'ensemble des systèmes d'information de TechShop SAS (WooCommerce, Odoo, Google Workspace)
- L'infrastructure technique hébergée (OVH, AWS, Cloudflare)
- Tous les collaborateurs, prestataires et partenaires accédant aux systèmes TechShop
- Les données traitées : clients, commandes, ressources humaines, finances

2. Déclaration d'intention de la direction

"En huit ans, TechShop a construit sa réputation sur la qualité de ses produits et la fiabilité de son service. Aujourd'hui, avec 15 000 clients qui nous font confiance avec leurs données personnelles et une dépendance totale à notre infrastructure numérique pour générer notre chiffre d'affaires, nous ne pouvons plus traiter la sécurité comme un sujet secondaire ou purement technique. J'ai vu des PME de notre taille disparaître en quelques semaines après un ransomware ou une amende CNIL. Ce n'est pas une probabilité abstraite — c'est un risque réel pour nos employés, nos clients et notre activité. C'est pourquoi j'engage formellement TechShop SAS dans cette démarche de certification ISO 27001, avec les moyens humains et financiers nécessaires pour aller au bout. Thomas et Sophie ont mon soutien complet. Les décisions prises dans le cadre de ce SMSI engagent la direction — pas seulement l'équipe IT." Marie Laurent — Directrice Générale, TechShop SAS — Juin 2026

3. Objectifs de sécurité

La politique de sécurité de TechShop SAS repose sur la triade **CIA** et un quatrième pilier propre au contexte e-commerce :

3.1 Confidentialité

Garantir que les données personnelles des clients (15 000 personnes), les données RH des employés et les informations commerciales sensibles ne sont accessibles qu'aux personnes autorisées. Toute divulgation non autorisée est traitée comme un incident de sécurité majeur.

3.2 Intégrité

Assurer que les données traitées par TechShop (commandes, stocks, données clients) sont exactes, complètes et protégées contre toute modification non autorisée ou accidentelle.

L'intégrité des systèmes de paiement (Stripe) est déléguée contractuellement avec garantie PCI-DSS.

3.3 Disponibilité

Maintenir la disponibilité des services critiques (site e-commerce, ERP Odoo) à un niveau minimum de 99,5% mensuel. Toute interruption non planifiée supérieure à 4 heures déclenche l'activation du Plan de Reprise d'Activité (PRA).

3.4 Conformité (Accountability)

Démontrer en permanence la conformité aux obligations légales et réglementaires applicables : RGPD (UE 2016/679), NIS2 (UE 2022/2555), et les exigences contractuelles clients B2B.

4. Principes directeurs

Toute décision de sécurité chez TechShop SAS s'appuie sur les principes suivants :

Principe	Application
Moindre privilège	Chaque utilisateur n'accède qu'aux ressources strictement nécessaires à sa fonction
Défense en profondeur	Plusieurs couches de protection (WAF + authentification + chiffrement + backup)
Security by default	La configuration par défaut de tout système doit être sécurisée
Traçabilité	Toute action sur un système critique est journalisée et conservée 1 an minimum

Principe	Application
Amélioration continue	Le SMSI est révisé annuellement et après chaque incident significatif

5. Rôles et responsabilités

Rôle	Titulaire	Responsabilités sécurité
Directrice Générale	Marie Laurent	Approbation de la politique, validation des risques résiduels, budget sécurité
Directeur des Systèmes d'Information (DSI)	Thomas Rivet	Mise en œuvre technique du SMSI, gestion des incidents, plan de traitement
Délégué à la Protection des Données (DPO)	Sophie Blanc	Conformité RGPD, registre des traitements, notification CNIL, droits des personnes
Responsable RH	À désigner	Processus d'intégration/départ sécurisé, formation des employés
Tous les employés	47 collaborateurs	Respecter la charte informatique, signaler tout incident suspect à sécurité@techshop.fr
Prestataires et sous-traitants	Contrats en vigueur	Respecter les clauses sécurité contractuelles, signaler tout incident affectant TechShop

6. Obligations des collaborateurs

Tout collaborateur de TechShop SAS s'engage à :

- **Protéger ses identifiants** — Ne jamais partager son mot de passe ni ses clés d'accès
- **Utiliser le MFA** — Activer l'authentification multi-facteurs sur tous les comptes professionnels
- **Signaler les incidents** — Toute anomalie suspecte est signalée immédiatement à sécurité@techshop.fr
- **Respecter la classification** — Ne pas diffuser d'informations classifiées "Confidentiel" ou "Secret" hors périmètre autorisé
- **Verrouiller son poste** — Verrouillage automatique après 5 minutes d'inactivité
- **Ne pas installer de logiciels non autorisés** — Toute installation doit être validée par le DSI

Le non-respect de ces obligations est susceptible de sanctions disciplinaires conformément au règlement intérieur de TechShop SAS.

7. Gestion des risques

TechShop SAS applique la méthode **EBIOS RM** (ANSSI 2018) pour l'identification, l'analyse et le traitement des risques de sécurité. Le registre des risques est révisé :

- Annuellement (revue planifiée)
- Après tout incident de sécurité significatif
- Lors de tout changement majeur du système d'information

Le Plan de Traitement des Risques (PTR) définit les mesures à mettre en œuvre pour réduire les risques à un niveau acceptable. Les risques résiduels sont formellement acceptés par la Directrice Générale.

8. Gestion des incidents

Tout incident de sécurité doit être signalé dans un délai maximum de **4 heures** après détection au DSI et au DPO. En cas de violation de données personnelles, la notification à la CNIL doit intervenir dans les **72 heures** (Art. 33 RGPD).

Les niveaux de priorité sont définis comme suit :

- **P1 — Critique** : Système en production indisponible ou données compromises -> réponse < 1h
- **P2 — Élevé** : Compromission partielle ou risque imminent -> réponse < 4h
- **P3 — Modéré** : Vulnérabilité identifiée sans exploitation active -> réponse < 72h

9. Relations avec les fournisseurs

Les fournisseurs et sous-traitants traitant des données TechShop ou ayant accès aux systèmes doivent :

- Signer un accord de traitement des données (DPA) conforme au RGPD Art. 28
- Respecter un niveau de sécurité équivalent à celui de TechShop SAS
- Notifier TechShop de tout incident de sécurité dans les 24 heures

Fournisseurs critiques identifiés : OVH, AWS, Stripe, Cloudflare, Google Workspace.

10. Conformité légale et réglementaire

TechShop SAS s'engage à respecter en permanence :

Réglementation	Périmètre	Responsable
RGPD (UE 2016/679)	Données personnelles clients et RH	DPO — Sophie Blanc
NIS2 (UE 2022/2555)	Sécurité réseau et systèmes	DSI — Thomas Rivet

Réglementation	Périmètre	Responsable
PCI-DSS	Paieement en ligne (délégué à Stripe)	DSI — Thomas Rivet
Code du travail	Données RH, surveillance des employés	DRH + DPO
ISO 27001:2022	SMSI global	DSI + DPO

11. Engagement de revue annuelle

La présente politique est révisée **au minimum une fois par an**, lors de la revue de direction

(Clause 9.3 ISO 27001), ou de manière anticipée en cas de :

- Changement significatif de l'activité ou du système d'information
- Incident de sécurité majeur
- Évolution réglementaire impactant TechShop SAS

Prochaine révision obligatoire : Juin 2027

Signatures

Rôle	Nom	Signature	Date
Directrice Générale	Marie Laurent	<i>[Signé]</i>	Juin 2026
Directeur SI	Thomas Rivet	<i>[Signé]</i>	Juin 2026
DPO	Sophie Blanc	<i>[Signé]</i>	Juin 2026

Document classifié : INTERNE — Ne pas diffuser hors de TechShop SAS sans autorisation DG

Archivage : Google Drive / SMSI / 01-Politique — Rétention : 5 ans après révision